

ILLUSTRATIVE EXEMPLAR — “what good looks like”

Premarket Cybersecurity Documentation

Modular, EMR-connected infusion system (Class II, 510(k))

Grounded in (public record): BD Alaris™ Infusion System — FDA 510(k) cleared July 2023 (updated software with enhanced cybersecurity + EMR interoperability; remediated the 2020 Class I recall of ~774,000 devices). Public source: BD press release, news.bd.com (2023-07-21).

Regulatory basis: FD&C; Act §524B; FDA Premarket Cybersecurity Guidance (final, 2025-06-27); AAMI SW96; ISO 14971; IEC 81001-5-1.

1. Cyber-device determination

The system is a **cyber device** under §524B: a modular point-of-care unit (PCU) with large-volume, syringe, and PCA pump modules, wired/wireless network connectivity, and bidirectional EMR interoperability. Connectivity (Wi-Fi + wired Ethernet + maintenance USB) brings it within scope of the 2025 guidance.

2. Security risk management (AAMI SW96 / ISO 14971)

Security risk is managed in a dedicated file integrated with the safety risk file. Risks are scored on exploitability and patient-harm independently; residual risks are formally accepted by Quality and Product Security.

ID	Asset / interface	Threat (STRIDE)	Control	Residual
S-01	Wireless module link	Spoofing	Mutual-TLS, device certificates, 802.1X	Low (accepted)
S-02	Drug library / DERS update	Tampering	Signed packages, integrity verification	Low
S-03	EMR interoperability (HL7/FHIR)	Information disclosure	TLS 1.2+, scoped interfaces, audit logging	Low
S-04	Maintenance USB port	Elevation of privilege	Port lockdown, signed service tools, RBAC	Low (accepted)
S-05	PCU availability	Denial of service	Local autonomy, watchdog, safe-state on fault	Medium (accepted)

3. Threat model

A STRIDE model spans the PCU, pump modules, wireless/wired networking, the maintenance interface, the drug-library/DERS update path, and EMR integration. Each threat traces to a control and a verification test (see §6).

4. Security architecture views

- **Global system view** — PCU, modules, network, server-side drug-library service, EMR gateway, trust boundaries.
- **Multi-patient harm view** — blast radius if a shared server or drug library is compromised.
- **Updateability / patchability view** — signed software and drug-library update path with rollback.

- **Security use-case views** — clinician auth, service access, EMR association, key/cert management.

5. Security controls (eight categories)

Category	Implementation (summary)
Authentication	Role-based clinician/service auth; device-to-server mutual-TLS
Authorization	Least-privilege roles; service functions gated
Cryptography	TLS in transit; signed firmware/drug library; keys in hardware-backed store
Code & data integrity	Secure boot, signed images, anti-rollback
Confidentiality	Encryption of PHI in transit; minimized data at rest
Event detection / logging	Security event logs exported to hospital SIEM
Resiliency / recovery	Local infusion autonomy; safe-state; restore from signed image
Firmware / software updates	Authenticated, staged updates with verification and rollback

6. Cybersecurity testing

Activity	Scope	Result
SAST	Full firmware + app source	Findings triaged; criticals resolved
SCA / SBOM analysis	All third-party components	0 known critical CVEs at submission
DAST	Network services + EMR interface	No unauthenticated exposure
Fuzzing	Protocol parsers (HL7/FHIR, update)	No exploitable crashes
Penetration test	Independent accredited lab	All findings closed or risk-accepted

7. SBOM (excerpt)

Component	Version	Support / EOL	Known vulns
Embedded RTOS	x.y	Supported	0 critical
TLS library	x.y.z	Supported (LTS)	0 critical
HL7/FHIR parser	x.y	Supported	0 critical
Logging library	x.y	Supported	0 critical

Delivered as machine-readable CycloneDX 1.5 with supplier, license, support level, and end-of-support per component.

8. Postmarket management & CVD

- Continuous SBOM→CVE and CISA KEV monitoring; vendor PSIRT feeds.
- Coordinated Vulnerability Disclosure policy with safe-harbor and SLAs; CVEs via CNA.
- Patch SLAs by severity; customer notification ≤ 30 days; 21 CFR 806/803 assessment triggers defined.

9. Labeling

Security labeling and an MDS2 form describe supported configurations, network requirements, controls, update mechanism, and known limitations; a hardening guide ships with the device.

10. Conclusion

The documentation demonstrates a **reasonable assurance of cybersecurity** for a connected infusion system consistent with §524B and the 2025 premarket guidance.